Executive ISO 27001 & NIST CSF 2.0 Gap Analysis & Risk Remediation Report

Note: This is a portfolio project. The company, interviews, and findings are fictional and simulated. The compliance score is illustrative, not an ISO metric.

Target Organization: VortexPe Cloud Services India Pvt. Ltd.
Assessment Date: October 2026
Target Scope: AWS Production Infrastructure, Kubernetes (EKS) Clusters, Financial APIs, and Customer PII Repositories
Evaluated Frameworks: ISO/IEC 27001:2022 (Annex A), NIST CSF 2.0, Digital Personal Data Protection (DPDP) Act 2023

1. Executive Summary

A comprehensive enterprise information security gap assessment was conducted for VortexPe Cloud Services to evaluate the baseline security posture of its cloud-native fintech platform against **ISO/IEC 27001:2022** and **NIST CSF 2.0**.
The overall calculated compliance score for VortexPe is **50.0% across 9 applicable controls**. Out of 10 total controls evaluated, 1 control (Physical Security) is inherited from AWS under the Shared Responsibility Model and is not scored, 2 controls are Fully Implemented, 5 are Partially Implemented, and 2 are Not Implemented.

While baseline operational logging (ISO A.8.15) and vulnerability management (ISO A.8.8) demonstrate strong maturity, **two Critical-risk gaps** pose significant compliance and operational exposure:

1. **1. DPDP Act 2023 Compliance Exposure (A.8.12 / PR.DS-01):** Unmasked customer PII is present in staging/non-production environments without data masking or automated Data Leakage Prevention (DLP).
2. **Business Continuity Gap (A.5.29 / RC.RP-01):** Absence of multi-region database failover testing and undocumented RTO/RPO metrics jeopardize the 99.9% uptime SLA for core financial APIs.

2. Enterprise Compliance & Risk Metrics

Table 1: Compliance Status Summary

Metric	Count	Percentage of 10 Controls Evaluated	Notes / Status
Total Controls Evaluated	**10**	100%	Full audit scope covering Cloud, IAM, Data, BCP, & DevSecOps
Applicable Controls (SoA)	**9**	90.0%	Controls within direct operational boundary
Inherited Controls (SoA)	**1**	10.0%	Inherited via AWS SOC 2 Type II / ISO 27001 (A.7.1 Physical Security)
Fully Implemented Controls	**2**	20.0%	Log Stream WORM Storage & Weekly Container CVE Scanning
Partially Implemented Controls	**5**	50.0%	AWS IaC Baselines, IAM MFA, K8s Image Signing, KMS Keys, SAST
Not Implemented Controls	**2**	20.0%	Non-prod PII Masking/DLP & Multi-Region DR Failover Testing
Overall Compliance Score	**50.0%**	—	Calculated as (Fully Implemented × 1.0 + Partially Implemented × 0.5) / 9 applicable controls (illustrative).

Table 2: Inherent Risk Profile Breakdown

Inherent Risk Rating	Control Count	Target Remediation Window	Primary Focus Areas
CRITICAL	**2**	**30 Days**	Non-prod PII Exposure (A.8.12) & Unverified DR Failover (A.5.29)
HIGH	**4**	**30 to 60 Days**	Manual AWS Config (A.5.23), CLI MFA Gaps (A.5.15), Unsigned K8s Containers (A.8.9), Manual SAST (A.8.28)
MEDIUM	**1**	**60 Days**	Default KMS Key Management (A.8.24)
LOW	**3**	**90 Days / Maintain**	Centralized Logging (A.8.15), Automated CVE Scanning (A.8.8), Physical Security (A.7.1 - Inherited)

3. Detailed Gap Findings & Exposure Analysis

Finding 1: Unmasked Customer PII in Non-Production Environments (CRITICAL)

- **Mapping:** ISO 27001:2022 A.8.12 (primary), A.8.11, A.8.33 | NIST CSF PR.DS-01 | DPDP Act 2023 (Data Fiduciary security safeguards, Sec 8)
- **Condition:** Production database snapshots containing customer PII (PAN, phone numbers, transaction history) are cloned into staging without data masking or tokenization, and no automated DLP monitoring is in place.
- **Criteria:** A.8.11 requires data masking where appropriate; A.8.33 requires test information to be selected, protected, and managed; A.8.12 requires data leakage prevention measures.
- **Cause (likely, to be confirmed with management):** The snapshot-restore pipeline has

no masking step, and staging is treated as lower risk.
- **Effect:** A staging or developer-device compromise would expose real customer data, creating regulatory, legal, and reputational exposure under the DPDP Act.
- **Recommendation:** Add masking or tokenization to the snapshot-restore pipeline, restrict staging access, and use AWS Macie to scan S3 exports and backups for PII.

Finding 2: Disaster Recovery Failover Not Tested (CRITICAL)

- **Mapping:** ISO 27001:2022 A.5.29 (also A.5.30) | NIST CSF ID.IM-02
- **Condition:** No multi-region failover test or simulation has been performed in the past 12 months, and RTO/RPO are not documented in customer contracts.
- **Criteria:** A.5.29 requires information security to be maintained during disruption; A.5.30 requires ICT readiness to be planned, implemented, maintained, and tested against business continuity objectives.
- **Cause (likely, to be confirmed with management):** DR capability exists in design, but no recurring test schedule has been set.
- **Effect:** A regional outage could extend downtime and breach the 99.9% uptime SLA during live transaction processing.
- **Recommendation:** Define RTO/RPO through a business impact analysis (proposed starting point: 4 hours / 15 minutes), document the DR runbook, and run a multi-region failover drill.

Finding 3: No MFA Enforcement on AWS CLI/API Access (HIGH)

- **Mapping:** ISO 27001:2022 A.8.5, A.5.15 | NIST CSF PR.AA-03
- **Condition:** AWS console logins enforce MFA, but CLI/API access uses long-lived access keys with no MFA session requirement.
- **Criteria:** A.8.5 requires secure authentication appropriate to access restrictions and risk; A.5.15 requires access to be controlled according to business and security **requirements.**
- **Cause (likely, to be confirmed with management):** Long-lived access keys were issued for convenience and never moved to short-lived sessions.
- **Effect:** A leaked or stolen key could give administrative control of cloud resources without an authentication challenge.
- **Recommendation:** Require MFA-backed short-lived session credentials for privileged CLI/API actions, and retire long-lived admin keys.

Finding 4: Container Image Signatures Not Enforced in Production EKS (HIGH)

- **Mapping:** ISO 27001:2022 A.8.9 | NIST CSF PR.PS-05
- **Condition**: Per the simulated DevOps Lead interview, images are signed in some build pipelines, but the EKS clusters have no admission control that rejects unsigned or unverified images.
- **Criteria:** Secure configuration of the deployment environment (A.8.9) should prevent installation and execution of unauthorized software (PR.PS-05)**.**
- **Cause (likely, to be confirmed with management):** Signing was adopted per pipeline without a cluster-level enforcement policy.
- **Effect:** Unverified or tampered images could run in production namespaces, creating a software supply chain risk.
- **Recommendation:** Enforce signature verification with Kyverno or Cosign admission policies, starting in audit mode and then moving to block mode.

4. 30-60-90 Day Remediation Roadmap

Phase 1: Immediate Risk Reduction (0 - 30 Days)
- Implement Dynamic PII Data Masking in Non-Prod Staging
- Enforce Mandatory Hardware/TOTP MFA on AWS CLI/API Session Credentials
- Conduct Multi-Region DR Failover Simulation & Document RTO/RPO

Phase 2: Secure Architecture & Guardrails (31 - 60 Days)
- Deploy Terraform Infrastructure as Code (IaC) Baselines & GuardDuty
- Enforce Container Image Signature Verification via Kyverno on EKS
- Transition Cloud Encryption to Customer Managed Keys (CMK) with 90-Day Rotation
- Integrate SAST Scans (SonarQube/Semgrep) into GitHub Actions Build Pipelines

Phase 3: Continuous Governance & Optimization (61 - 90 Days)
- Establish Automated Compliance Monitoring & Drift Alerts
- Perform Annual Third-Party Vendor SOC 2 / ISO Certification Review
- Prepare Final ISO 27001 Annex A Audit Evidence Package

Table 3: Actionable Remediation Plan

Milestone	Action Item	Target Control	Primary Owner	Resource / Tooling Required
30 Days	Deploy dynamic schema masking for database staging clones.	ISO A.8.12 / DPDP	Database Admin	Database masking tooling / pipeline scripts
30 Days	Enforce conditional IAM policies requiring MFA for AWS CLI keys.	ISO A.5.15	IAM / SecOps	AWS IAM Conditional Policies
30 Days	Conduct multi-region database failover drill and publish RTO/RPO.	ISO A.5.29	Infrastructure	AWS Aurora Global DB / Route 53
60 Days	Convert console-built AWS resources into Terraform IaC templates.	ISO A.5.23	DevOps	HashiCorp Terraform
60 Days	Block unsigned container image deployments in production EKS.	ISO A.8.9	DevSecOps	Cosign / Kyverno Admission Control

60 Days	Shift KMS from AWS-managed keys to Customer Managed Keys (CMK).	ISO A.8.24	SecOps	AWS KMS
60 Days	Embed SAST security gates directly into GitHub Actions pipelines.	ISO A.8.28	Engineering	SonarQube / Semgrep CI/CD
90 Days	Execute quarterly log retention and SIEM WORM lock audit.	ISO A.8.15	SOC Lead	AWS S3 Object Lock / SIEM
90 Days	Review third-party AWS SOC 2 Type II reports for physical controls.	ISO A.7.1	Compliance Lead	AWS Artifact Governance Portal

5. Strategic Governance & Compliance Recommendations

1. **Adopt Security-as-Code Guardrails:** Transition away from manual cloud management by requiring all cloud provisioning to pass through code-reviewed Infrastructure as Code (IaC) pipelines with static security scanning (Checkov / TFSec).
2. **Institute Continuous Compliance Monitoring:** Implement continuous compliance scoring tools (AWS Audit Manager / Security Hub) mapped directly to ISO 27001:2022 Annex A and NIST CSF 2.0 to maintain real-time visibility into control status.
3. **Establish Monthly CISO Steering Reviews:** Track the execution of the 30-60-90 day remediation roadmap during monthly executive risk reviews to ensure zero overdue critical or high findings prior to formal ISO 27001 certification auditing.